

WAYMO V. UBER - CASE STUDY REPORT
Insider Threats

Date of Submission: 22 June 2026

Group 30

Student Name&ID: Shah Md Julhash Tamim (101002572)
& Faishal Youshuf (101044804)
Ontario Tech University

Executive Summary

The company, called Waymo, is a big fish in a small pond – an innovative technology company with a lot of interest in attracting people to steal things like trade secrets and/or Intellectual Property (IP). In 2017, Waymo filed a high-profile lawsuit against Uber Technologies, Inc. when its lead engineer Anthony Levandowski left, as part of the legal action.

This report reveals gaps in access control, employee offboarding, data loss prevention (DLP) and employee insider threat monitoring systems. The case highlighted both organizations as being heavily exposed to financial loss, damage to reputation and competitive loss, with issues of sourcing confidential data and IP in a mobile, talent competitive environment. It provides practical, evidence-based recommendations for cybersecurity based on the cybersecurity principles and frameworks presented in NIST SP 800-207, principles of ZTA, and the Insider Threat Mitigation Guide by the Cybersecurity and Infrastructure Security Agency (CISA).

Background of the incident

Organizational Context

Waymo is an Alphabet division (Google's parent company) that focuses on the development of autonomous driving technology. The main benefits that Waymo has is that they have their own algorithms, original engineering design, bespoke hardware and software, and specifically their Light Detection and Ranging (LiDAR) technology. These are valuable trade secrets pursuant to the federal U.S. Defend Trade Secrets Act (DTSA).

Engineers in these categories have access to extremely confidential and sensitive data, such as source code, circuit board designs, and training data for systems, on internal computers. As described in Super Pumped (Isaac, 2019), the tech competition to win the most with the new technology resulted in a catch as catch can atmosphere where people were being poached for their skills and inside attacks were rife.

Summary of key cases

Case	Year	Allegation	Outcome
Waymo LLC v. Uber Technologies, Inc.	2017	In an accusation that Uber later bought into, Waymo claimed that Anthony Levandowski stole 14,000 secret files about LiDAR technology from the company when he started his Otto project.	Settled mid-trial in 2018. Uber has committed to giving Waymo \$245 million in equity, and has signed a “binding mandate” that the company's IP would not be incorporated into Uber's hardware or software.
United States v. Anthony Levandowski	2019	Federal criminal charges, alleging 33 counts of violating the DTSA's trade secret theft laws.	Charges were brought against him and he pled guilty to 1 count of illegal acquisition of a trade secret. Convicted to 18 months prison (later pardoned).

In this case, the ex-worker had access to confidential data, and exfiltrated that information just prior to his leaving and used the “stolen” IP to launch a competing business.

Technical analysis

Attack Vectors and Exfiltration Techniques

The methods used to exfiltrate information were fairly straightforward, and simple technical controls to monitor, detect, and/or prevent insider data theft were not well in place.

1. **Bulk File Downloads from Internal Repositories:** In December 2015, Levandowski added special software to log onto and download 9.7 GB of data (more than 14,000 files) from Waymo's internal Subversion (SVN) servers.

2. **Unauthorized Removable Media:** The files were copied off of his company-provided laptop to external media such as SD cards.
3. **Forensic Evasion:** For the past two years, LeVandowski has been systematically stripping the corporate laptops that he used of operating system logs and registry artifacts before returning them when he resigned.

This incident was caused by multiple technical control failures.

Technical control failures

Data Loss Prevention (DLP)

A good DLP solution monitors and controls data transfer across endpoints, email, cloud files and removable storage. With proper implementation, DLP will be able to classify and protect source code and engineering files at the right sensitivity level. Thousands of proprietary files should have been downloaded to a local machine/external media and alert should have been triggered or should not have been permitted.

User and Entity Behavior Analytics (UEBA)

UEBA tools establish user-specific baseline behaviors and send them alerts if content is downloaded in unusual amounts, beyond a user's typical lines of access. If you've lost the entire repository, you should have received a critical notification.

Privileged Access Management (PAM) and Least Privilege

Engineers were free to use many IP without restriction and no monitoring. The autonomous project had thousands of design files accessible to Levandowski via administrative access. If a policy of least-privilege access is followed as outlined in NIST SP 800-207, this would dramatically limit the amount of data that could be stolen.

Endpoint Detection and Response (EDR)

The ability to monitor events that occur when a user accesses, copies, or transfers files to or from an endpoint is called EDR solutions. The user could completely wipe and format the corporate device, without leaving any logs offsite, creating blind spots for the insider to take advantage of.

Offboarding Access Revocation

Exfiltration also occurred weeks before the employee officially resigned, indicating there was no ongoing monitoring and no triggering of security events up until the separation date.

Policy, Governance, and Risk Analysis

Policy Failures

There are a series of policy failures that have led to the Waymo IP theft case:

Policy Area	Failure Identified
Acceptable Use Policy (AUP)	Failure to have a good technical control to stop the transfer of work-related information to unauthorized removable media.
Offboarding Policy	Access revocation and Digital Forensic Sweeps were not done concurrently, but instead, he had unfettered access until he separated.
Access Control Policy	There was no granular role based access control (RBAC), hence engineers were able to access IP outside and beyond their functional project needs.
Monitoring and Audit Policy.	High risk of monitoring policy gaps was identified as bulk downloads and unusual transfers were not identified during real-time downloads.
Vendor/M&A Policy	Uber's third party due diligence and security vetting of the acquisition of Otto missed the tainted IP.

Governance Failures

The situation suggests that, given both organizations' technological sophistication, sophisticated insider threat governance was lacking. Key gaps included:

1. **No formal Insider Threat Program (ITP):** CISA (2020) says that HR, legal, IT and security functions should be combined into one program. Not enough work was done to detect behavioral anomalies with an active ITP.
2. **Failure to enforce the security culture:** Waymo had a very trusting engineering culture instead of a security by default approach.
3. **Delayed incident detection:** Waymo did not detect the data theft until after the employee had left, which means it did not monitor proactively.

Risk Analysis

This case exemplifies the textbook malicious insider threat case. Factors that caused higher exposure were:

1. **Billion dollar opportunities:** Autonomous driving algorithms and LiDAR hardware.
2. **Competitive talent market:** Competitive talent markets such as autonomous vehicles result in more churn among the employees of competing companies, raising the likelihood of corporate espionage.
3. **Access is flexible:** a common trait in an engineering organization that can cause vulnerabilities that are exploited by malicious actors in the trust-based access model.

Incident Response and Recovery

Detection and Initial Response

Waymo didn't notice the incident until well after it had taken place. The exit was only discovered when an email chain from *Isaac (2019)*, who works for a vendor of parts for the LiDAR, accidentally ended up in Waymo's hands, with the company's drawings for the machines matching the ones that Waymo uses. Waymo responded by:

1. Beginning a forensic audit of the SVN logs in the past.
2. Acting swiftly with civil action and applying for Emergency injunction against Uber.
3. Scheduling meetings with attorneys to take the case to federal prosecution; ultimately making a federal criminal referral.

Effectiveness of Response

In 2017, Waymo LLC prevailed in another trial to obtain a \$245 million equity settlement and an injunction forbidding disclosure of its trade secrets in *Waymo LLC v. Uber Technologies, Inc.* However, a drawback of this was its reactive nature, meaning the initial data confidentiality was lost. Once the loss of confidentiality has taken place, the remedies which the law can provide are forever restricted.

Lessons learned and recommendations

Lessons Learned

1. Claims after the event are not sufficient – IP disclosure is hindering the competition. Early detection is key to prevention.
2. Insider threats are a people, process and technology issue – Technology is not the answer to thwarting threats unless there are the proper policies and governance, and an integrated Insider Threat Program (CISA, 2020).

3. If an employee is leaving your organization, it's a security event: When a staff member is leaving your company, it's a high-risk time. The worker/employer connection needs to be looked on closely.
4. For high value IP, all of the employees, including the lead engineers, should only have access to the data that is needed for this project; this is called least privilege.
5. It is critical that behavioral monitoring is put in place: Any UEBA solution that can detect suspicious access patterns as early as possible is key to detection.

Recommendations

There are several changes that need to be made to decrease the chances of future IP theft:

1. Access Controls: Transition to a Zero Trust Architecture (NIST, 2020). Employ least privilege access and micro-segmentation to limit employee access to only what they need, based on the nature of their work.
2. Monitoring and DLP: Alert on and prevent unusual transactions such as big files being downloaded, or external drives being connected. Effective DLP solutions should be able to detect and prevent unauthorized transfer of sensitive data.
3. Have well established exit protocols. This covers all the necessary computer forensics which can be carried out on any devices, and the immediate blocking of all sensitive repositories if a device is suspected to be leaving the company and/or a resignation notice is received.
4. M&A Due Diligence: A startup independent 'clean room' audit of the startups source code and hardware pedigree is important when acquiring a startup.
5. Culture and Training: Conduct frequent training on security awareness to inform employees about insider threat risks and associated legal ramifications of IP theft.

Conclusion

The Waymo-Uber situation is illustrative of an inside job conflict at a tech firm. Even the most technologically advanced organizations are vulnerable to insider threats due to inadequate levels of access control, monitoring and security governance on the resources they are securing. Businesses need to take data management seriously so as not to become a target for IP thefts. Prevention of insider threat must be a part of protecting the institution's IP; it can be accomplished through proactive measures such as a zero-trust architecture, effective DLP and security-aware offboarding. Although litigation works well, prevention works so much better and is a much safer approach.

8. References

1. *Cybersecurity and Infrastructure Security Agency (CISA). (2020). Insider Threat Mitigation Guide.*
2. *Isaac, M. (2019). Super Pumped: The Battle for Uber. W. W. Norton & Company.*
3. *National Institute of Standards and Technology (NIST). (2020). Zero Trust Architecture (NIST Special Publication 800-207).*
4. *Waymo LLC v. Uber Technologies, Inc., No. 3:17-cv-00939 (N.D. Cal. filed Feb. 23, 2017).*